UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

INGENIERÍA EN TECNOLOGÍAS DE LA INFORMACIÓN

Primera entrega proyecto parcial 2

Institución: Universidad Politécnica de San Luis Potosí

Materia:

CNO V – Seguridad Informática

Hecho por:

Cabrera Meza Jorge Alejandro – 181591

Profesor:

Mtro. Servando López Contreras

Eje temático del proyecto:

Documentación estructurada de proyecto del primer parcial enfocado a la información sobre la campaña de phishing

Fecha de entrega:

06 – Marzo – 2026

Indice

1.Marco teorico **2**
1.1 Ingeniería social y el factor humano en la seguridad informática 2
1.2 Phishing como tecnica principal de ingenieria social 2
1.3 Simulación de Phishing y concientización 3
1.4 Principales plataformas de simulacion de phishing 3
Hoxhunt 4
KnowBe4 4
Cofense 4
Phished 4
Infosec IQ 4
1.5 Metricas de evaluacion del error humano 4
1.6 Ética en la simulaciones de ingeniería social 5
2.0 Tabla técnica comparativa de plataformas de simulación de phishing **5**
Referencias 7

1.Marco teorico

1.1 Ingeniería social y el factor humano en la seguridad informática

La ingeniería social es un conjunto de técnicas de manipulación psicológica utilizadas por atacantes para influir en las personas y lograr que revelen información confidencial, realicen acciones inseguras o permitan acceso a sistemas protegidos. A diferencia de los ataques puramente técnicos, la ingeniería social explota principalmente el factor humano, considerado el eslabón más vulnerable dentro de la seguridad informática.

En el contexto social actual, los atacantes suelen aprovechar características humanas como la confianza, la curiosidad, el miedo o la urgencia para persuadir a las víctimas. Estas técnicas pueden presentarse en múltiples formas, incluyendo correos electrónicos falsos, llamadas telefónicas, mensajes de texto o páginas web fraudulentas. Debido a esto, la concientización y capacitación de los usuarios se ha convertido en una estrategia fundamental dentro de los programas modernos de ciberseguridad.

Según el informe de Verizon (2023), el phishing continúa siendo una de las principales técnicas utilizadas en ataques cibernéticos, lo que evidencia la importancia de entrenar a los usuarios para identificar amenazas potenciales.

1.2 Phishing como tecnica principal de ingenieria social

El phishing es una técnica de ingeniería social que consiste en el envío de mensajes fraudulentos que aparentan provenir de fuentes legítimas con el objetivo de obtener información sensible, como credenciales de acceso, datos personales o información

financiera. Generalmente estos ataques se distribuyen a través de correos electrónicos, aunque también pueden aparecer en redes sociales o mensajes SMS.

Los ataques de phishing suelen incluir elementos que aumentan su credibilidad, tales como logotipos corporativos, direcciones de correo similares a las originales, enlaces engañosos y mensajes que generan urgencia. El objetivo es inducir a la víctima a hacer clic en un enlace o descargar un archivo malicioso.

Dentro del ámbito de la capacitación en seguridad informática, se utilizan simulaciones de phishing como una estrategia educativa para evaluar el nivel de conciencia de los usuarios frente a estas amenazas. Estas simulaciones permiten identificar vulnerabilidades humanas sin generar riesgos reales para la organización.

1.3 Simulación de Phishing y concientización

Las simulaciones de phishing son herramientas utilizadas por organizaciones para evaluar y mejorar el nivel de preparación de los usuarios frente a ataques de ingeniería social. Estas simulaciones consisten en enviar correos electrónicos controlados que imitan ataques reales con el objetivo de medir el comportamiento de los usuarios ante posibles amenazas.

El propósito principal de estas simulaciones no es castigar a los usuarios, sino generar aprendizaje y concientización. Cuando un usuario interactúa con un mensaje simulado, el sistema puede proporcionar retroalimentación inmediata, explicando los indicadores que permiten identificar el ataque.

Entre las métricas comúnmente utilizadas para evaluar la efectividad de estas simulaciones se encuentran:

- **Tasa de apertura del correo:** porcentaje de usuarios que abrieron el correo simulado.
- **Tasa de clic en enlaces:** porcentaje de usuarios que hicieron clic en el enlace del phishing.
- **Tasa de ingreso de credenciales:** porcentaje de usuarios que introdujeron información sensible.
- **Tasa de reporte del phishing:** porcentaje de usuarios que identificaron y reportaron el ataque correctamente.

Estas métricas permiten evaluar el nivel de vulnerabilidad de una organización y diseñar estrategias de capacitación más efectivas.

1.4 Principales plataformas de simulacion de phishing

Existen diversas plataformas diseñadas específicamente para realizar simulaciones de phishing y programas de concientización en ciberseguridad. Estas herramientas permiten automatizar campañas de entrenamiento, generar reportes detallados y evaluar el comportamiento de los usuarios ante distintos escenarios de ingeniería social.

Entre las plataformas más utilizadas se encuentran:

Hoxhunt

Hoxhunt es una plataforma enfocada en el entrenamiento basado en inteligencia artificial que adapta las simulaciones de phishing según el nivel de riesgo de cada usuario. La plataforma utiliza gamificación y aprendizaje adaptativo para mejorar la capacidad de detección de amenazas.

KnowBe4

KnowBe4 es una de las plataformas de capacitación en seguridad más reconocidas a nivel mundial. Ofrece campañas automatizadas de phishing simulado, programas de entrenamiento interactivo y métricas detalladas sobre el comportamiento de los usuarios frente a amenazas.

Cofense

Cofense proporciona soluciones enfocadas en la defensa contra phishing mediante programas de concientización y herramientas para el análisis de correos maliciosos. Su enfoque principal es fortalecer la capacidad de los usuarios para identificar y reportar correos sospechosos.

Phished

Phished utiliza inteligencia artificial para personalizar las simulaciones de phishing y ajustar el nivel de dificultad según el comportamiento de cada usuario. Su objetivo es generar entrenamiento continuo que permita desarrollar habilidades de detección en entornos reales.

Infosec IQ

Infosec IQ es una plataforma de capacitación que combina simulaciones de phishing con programas educativos sobre seguridad informática. Incluye módulos de aprendizaje, campañas automatizadas y reportes de desempeño organizacional.

1.5 Metricas de evaluacion del error humano

El análisis del riesgo humano dentro de la ciberseguridad se basa en la medición del comportamiento de los usuarios frente a posibles amenazas. Las plataformas de simulación de phishing utilizan diversas métricas para evaluar el nivel de vulnerabilidad de una organización.

Entre las métricas más relevantes se encuentran:

- **Phish-prone percentage:** porcentaje de usuarios que caen en simulaciones de phishing.

- **Tiempo de detección:** tiempo que tarda un usuario en identificar o reportar un intento de phishing.
- **Nivel de repetición de errores:** frecuencia con la que un usuario vuelve a caer en simulaciones.
- **Tasa de mejora en el entrenamiento:** reducción del riesgo humano a lo largo del tiempo.

Estas métricas permiten a las organizaciones identificar áreas de mejora en sus programas de concientización y desarrollar estrategias de capacitación más efectivas.

1.6 Ética en la simulaciones de ingeniería social

El uso de simulaciones de phishing debe realizarse bajo principios éticos que protejan la privacidad y el bienestar de los participantes. Las campañas educativas deben evitar prácticas que puedan generar daño psicológico, exposición pública o sanciones injustas para los usuarios.

Las buenas prácticas en este tipo de simulaciones incluyen:

- Informar previamente a los participantes sobre la existencia de campañas de entrenamiento.
- No recopilar credenciales reales ni información sensible.
- Proporcionar retroalimentación educativa en lugar de castigos.
- Mantener la confidencialidad de los resultados individuales.

El objetivo principal de estas simulaciones es fortalecer la cultura de ciberseguridad dentro de las organizaciones, promoviendo el aprendizaje continuo y la reducción del riesgo humano.

2.0 Tabla técnica comparativa de plataformas de simulación de phishing

Plataforma	Tipo de solución	Características principales	Métricas y analítica	Integraciones	Enfoque de entrenamiento	Consideraciones éticas y limitaciones
Hoxhunt	Plataforma de entrenamiento en seguridad con simulaciones de phishing	Utiliza inteligencia artificial para personalizar ataques simulados según el nivel de riesgo del usuario. Incluye gamificación para aumentar la participación.	Reportes de comportamiento del usuario, detección de correos maliciosos, nivel de resiliencia frente al phishing.	Microsoft 365, Google Workspace, sistemas SIEM y plataformas de seguridad empresarial.	Entrenamiento adaptativo basado en comportamiento del usuario.	Enfocado en aprendizaje progresivo y retroalimentación educativa. Puede requerir integración técnica inicial.

KnowBe4	Plataforma integral de capacitación en seguridad y simulación de phishing	Ofrece campañas automatizadas de phishing, biblioteca de contenido educativo, videos de capacitación y evaluaciones de riesgo humano.	Phish-prone percentage, tasas de clic, tasas de reporte, métricas de mejora del usuario.	Active Directory, Microsoft 365, Google Workspace, herramientas SIEM.	Capacitación estructurada con campañas periódicas de simulación.	Puede generar saturación si se usan demasiadas campañas. Requiere gestión adecuada del programa de capacitación.
Cofense	Plataforma de defensa contra phishing y entrenamiento	Combina simulaciones de phishing con herramientas de detección y respuesta ante correos maliciosos.	Análisis de correos reportados, tasa de respuesta de usuarios, métricas de detección temprana.	Integración con plataformas de seguridad de correo electrónico y centros SOC.	Entrenamiento enfocado en detección y reporte de amenazas.	Diseñada principalmente para organizaciones con equipos de seguridad avanzados.
Phished	Plataforma de simulación de phishing basada en inteligencia artificial	Personaliza automáticamente los escenarios de phishing según el comportamiento del usuario.	Análisis del riesgo humano, seguimiento del progreso del usuario, reportes de vulnerabilidad.	Microsoft 365, Google Workspace y sistemas de gestión empresarial.	Aprendizaje continuo impulsado por inteligencia artificial.	Requiere recopilación de datos de comportamiento del usuario para optimizar la personalización.
Infosec IQ	Plataforma de capacitación en concientización de seguridad	Incluye simulaciones de phishing, módulos educativos, evaluaciones de conocimiento y seguimiento de progreso.	Métricas de desempeño, tasa de clic, tasa de reporte y análisis de tendencias.	LMS, Active Directory, Microsoft 365 y sistemas corporativos de autenticación.	Entrenamiento estructurado con contenidos educativos complementarios.	Algunos contenidos requieren adaptación cultural dependiendo del contexto organizacional.
Mimecast Awareness Training	Plataforma de concientización integrada con seguridad de correo	Permite ejecutar campañas de phishing simuladas integradas con protección de correo electrónico.	Métricas de interacción con correos simulados, reportes de vulnerabilidad de usuarios.	Integración con soluciones de seguridad de correo de Mimecast y sistemas empresariales.	Entrenamiento integrado con protección activa de correo electrónico.	Dependencia del ecosistema de productos Mimecast para aprovechar todas sus funciones.
Proofpoi	Plataforma de	Utiliza análisis del	Métricas de	Integración	Entrenamie	Puede requerir

nt Security Awarene ss	concientización y simulación de phishing	comportamiento para identificar usuarios de alto riesgo y personalizar el entrenamiento.	riesgo humano, reportes de comportamient o, análisis de tendencias de seguridad.	con soluciones de seguridad de Proofpoint y herramient as SIEM.	nto dirigido a usuarios con mayor nivel de riesgo.	infraestructura empresarial para aprovechar todas sus capacidades.

Referencias

- Cofense. (2023). *Phishing awareness and training platform overview*. https://cofense.com
- Infosec Institute. (2023). *Infosec IQ security awareness and phishing simulation platform*. https://www.infosecinstitute.com
- KnowBe4. (2024). *Security awareness training and simulated phishing platform*. https://www.knowbe4.com
- Phished. (2023). *AI-driven phishing simulation and awareness training*. https://phished.io
- Verizon. (2023). *Data breach investigations report*. Verizon Enterprise.
- Hoxhunt. (2024). *Security awareness and phishing training platform*. https://hoxhunt.com